

Configuring System Auditing with auditd

Scenario

You are the security administrator for SecureNet Corp., a company dealing with sensitive data. To improve security and comply with regulatory standards, you are Exercised with setting up system auditing to track critical events. You will use the

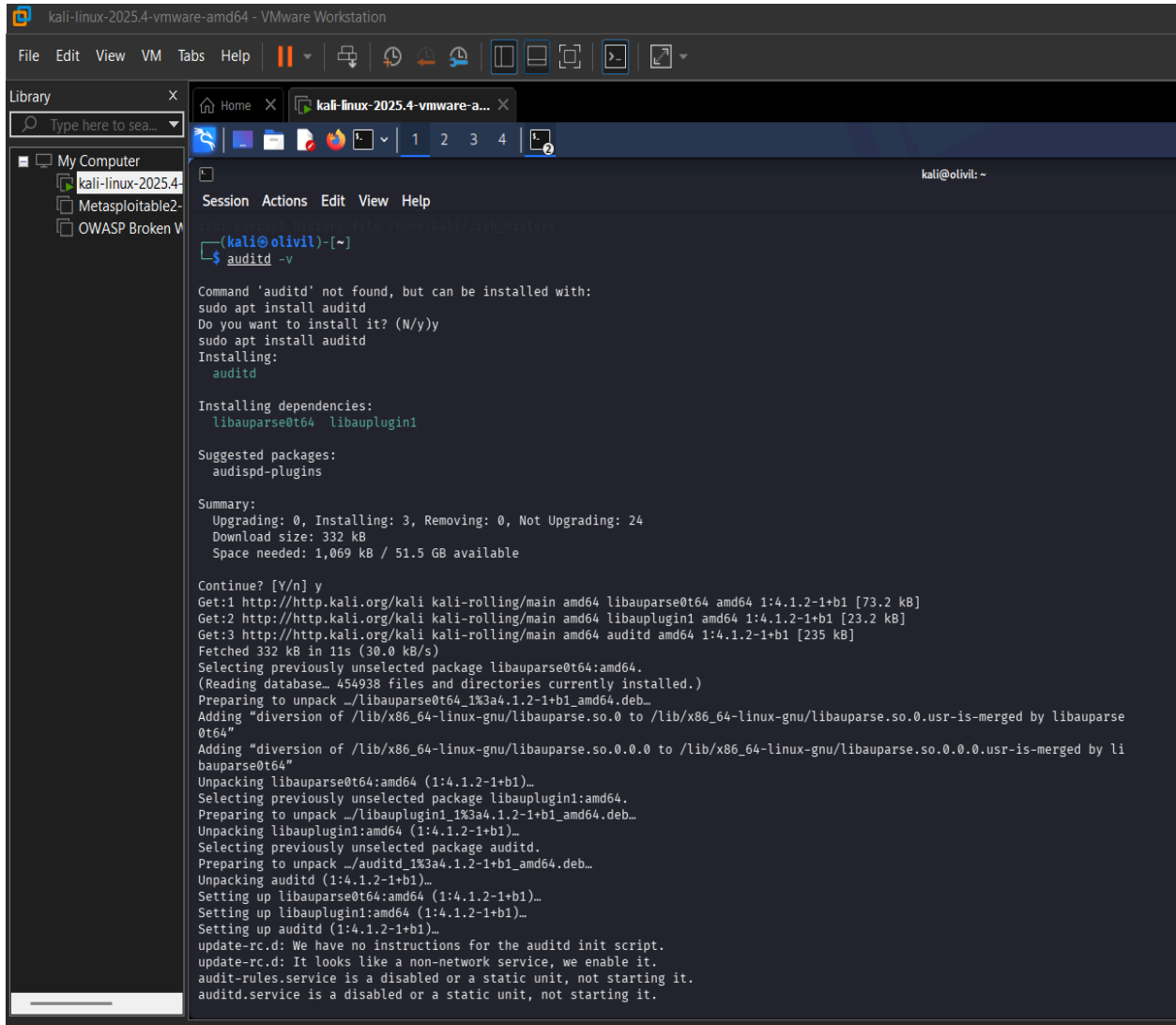
auditd

Your goal is to configure
auditd

Part 1: Install and Configure auditd

Commands used

```
sudo apt install auditd
sudo systemctl start auditd
sudo systemctl status auditd --no-pager
sudo systemctl enable auditd
sudo systemctl is-active auditd
sudo systemctl is-enabled auditd
```



```
ware-a... X
2 3 4 |
kali@olivil: ~

(kali@olivil)-[~]
$ auditd -v
auditd: invalid option -- 'v'
Usage: auditd [-f] [-l] [-n] [-s disable|enable|nochange] [-c <config_file>]

(kali@olivil)-[~]
$ sudo systemctl start auditd
[sudo] password for kali:

(kali@olivil)-[~]
$ sudo systemctl status auditd --no-pager
● auditd.service - Security Audit Logging Service
   Loaded: loaded (/usr/lib/systemd/system/auditd.service; disabled; preset: disabled)
   Active: active (running) since Sat 2026-08-15 10:10:04 EDT; 15s ago
     Invocation: 2e29a89a94294c97b53cab0e6a563177
       Docs: man:auditd(8)
             https://github.com/linux-audit/audit-documentation
    Process: 36817 ExecStart=/usr/sbin/auditd (code=exited, status=0/SUCCESS)
   Main PID: 36818 (auditd)
      Tasks: 2 (limit: 2066)
     Memory: 912K (peak: 2.5M)
        CPU: 26ms
    CGroup: /system.slice/auditd.service
            └─36818 /usr/sbin/auditd

Aug 15 10:10:04 olivil systemd[1]: Starting auditd.service - Security Audit...
Aug 15 10:10:04 olivil auditd[36818]: No plugins found, not dispatching events
Aug 15 10:10:04 olivil auditd[36818]: Init complete, auditd 4.1.2 listening...
Aug 15 10:10:04 olivil systemd[1]: Started auditd.service - Security Audit...
Hint: Some lines were ellipsized, use -l to show in full.

(kali@olivil)-[~]
$ sudo systemctl enable auditd
Created symlink '/etc/systemd/system/multi-user.target.wants/auditd.service' → '/usr/lib/systemd/system/auditd.service'.

(kali@olivil)-[~]
$ sudo systemctl is-active auditd
active

(kali@olivil)-[~]
$ sudo systemctl is-enabled auditd
enabled

(kali@olivil)-[~]
```

auditd was installed successfully and the audit service was started. The service status showed that it was running, and it was enabled to start automatically when Kali boots.

Part 2 Configure Audit Rules

View existing rules

```
sudo auditctl -l
```

Output: No rules

Open audit rules file

```
sudo nano /etc/audit/rules.d/audit.rules
```

Rules added

```
-w /var/log/auth.log -p wa -k user-logins  
-w /etc/passwd -p wa -k passwd-modifications
```

Apply the rules

```
sudo augenrules --load
```

Verify loaded rules

```
sudo auditctl -l
```



```
kali@olivil: ~  
$ sudo tail -n 10 /etc/audit/rules.d/audit.rules  
## This determine how long to wait in burst of events  
--backlog_wait_time 60000  
  
## Set failure mode to syslog  
-f 1  
  
-w /var/log/auth.log -p wa -k user-logins  
-w /etc/passwd -p wa -k passwd-modifications  
  
(kali@olivil)-[~]  
$ sudo augenrules --check  
/usr/sbin/augenrules: Rules have changed and should be updated  
  
(kali@olivil)-[~]  
$ sudo augenrules --load  
No rules  
enabled 1  
failure 1  
pid 489  
rate_limit 0  
backlog_limit 8192  
lost 0  
backlog 4  
backlog_wait_time 60000  
backlog_wait_time_actual 0  
enabled 1  
failure 1  
pid 489  
rate_limit 0  
backlog_limit 8192  
lost 0  
backlog 4  
backlog_wait_time 60000  
backlog_wait_time_actual 0  
enabled 1  
failure 1  
pid 489  
rate_limit 0  
backlog_limit 8192  
lost 0  
backlog 4  
backlog_wait_time 60000  
backlog_wait_time_actual 0  
Old style watch rules are slower
```

The existing audit rules were checked and no rules were initially loaded. Two rules were then added to monitor authentication logs and modifications to /etc/passwd. The rules were successfully loaded and verified with auditctl.

Part 3 Generate and Check Audit Logs

Commands Used:

1. Test user login

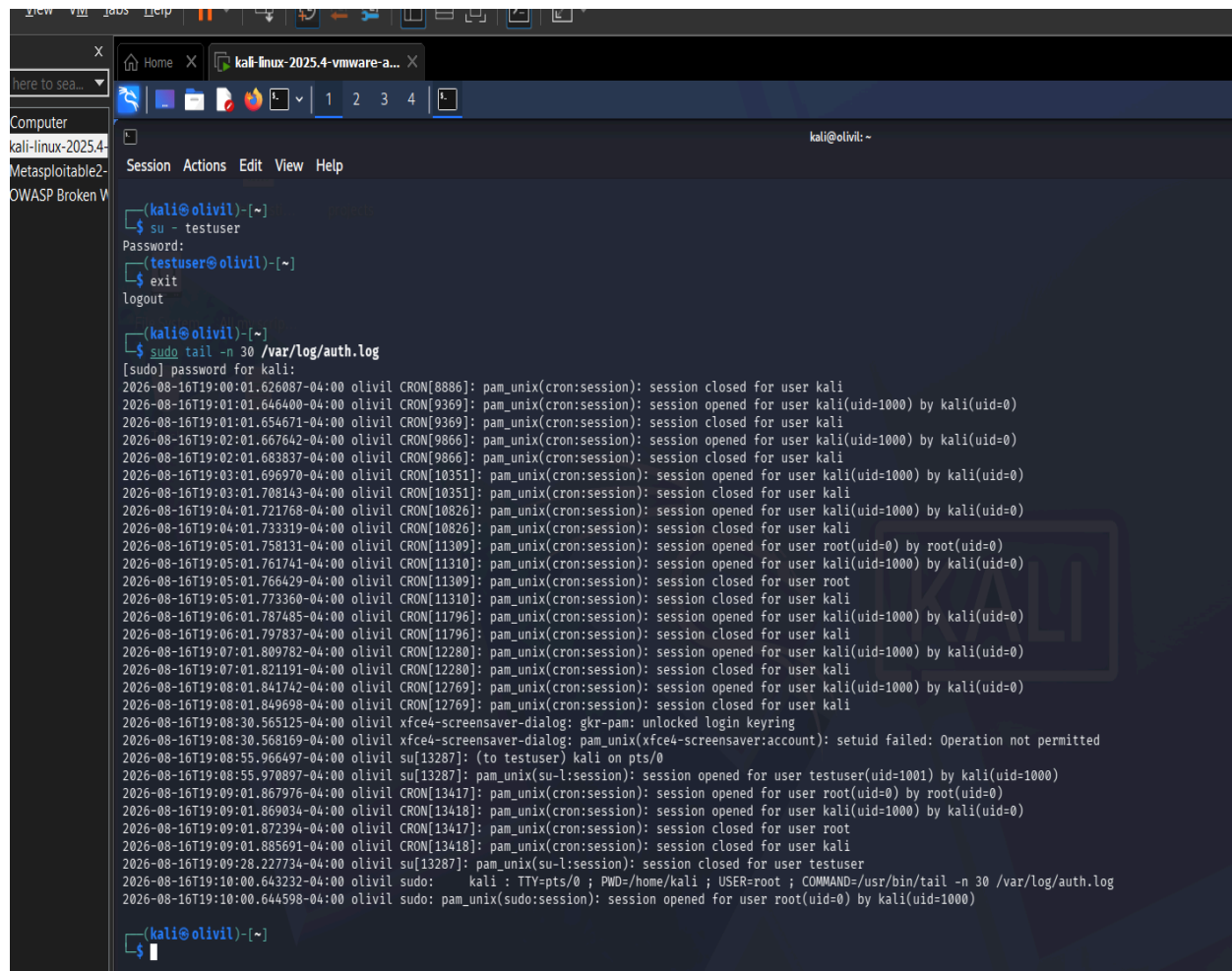
```
su - testuser
```

Then:

```
exit
```

2. Check authentication activity

```
sudo tail -n 30 /var/log/auth.log
```



```
kali@olivil: ~  
$ su - testuser  
Password:  
(testuser@olivil)~  
$ exit  
logout  
(kali@olivil)~  
$ sudo tail -n 30 /var/log/auth.log  
[sudo] password for kali:  
2026-08-16T19:00:01.626087-04:00 olivil CRON[8886]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:01:01.646400-04:00 olivil CRON[9369]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:01:01.654671-04:00 olivil CRON[9369]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:02:01.667642-04:00 olivil CRON[9866]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:02:01.683837-04:00 olivil CRON[9866]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:03:01.696970-04:00 olivil CRON[10351]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:03:01.708143-04:00 olivil CRON[10351]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:04:01.721768-04:00 olivil CRON[10826]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:04:01.733319-04:00 olivil CRON[10826]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:05:01.758131-04:00 olivil CRON[11309]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)  
2026-08-16T19:05:01.766429-04:00 olivil CRON[11309]: pam_unix(cron:session): session closed for user root  
2026-08-16T19:05:01.773360-04:00 olivil CRON[11310]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:06:01.787485-04:00 olivil CRON[11796]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:06:01.797837-04:00 olivil CRON[11796]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:07:01.809782-04:00 olivil CRON[12280]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:07:01.821191-04:00 olivil CRON[12280]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:08:01.841742-04:00 olivil CRON[12769]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:08:01.849698-04:00 olivil CRON[12769]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:08:30.565125-04:00 olivil xfce4-screensaver-dialog: gkr-pam: unlocked login keyring  
2026-08-16T19:08:30.568169-04:00 olivil xfce4-screensaver-dialog: pam_unix(xfce4-screensaver:account): setuid failed: Operation not permitted  
2026-08-16T19:08:55.966497-04:00 olivil su[13287]: (to testuser) kali on pts/0  
2026-08-16T19:08:55.970897-04:00 olivil su[13287]: pam_unix(su-l:session): session opened for user testuser(uid=1001) by kali(uid=1000)  
2026-08-16T19:09:01.867976-04:00 olivil CRON[13417]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)  
2026-08-16T19:09:01.869034-04:00 olivil CRON[13418]: pam_unix(cron:session): session opened for user kali(uid=1000) by kali(uid=0)  
2026-08-16T19:09:01.872394-04:00 olivil CRON[13417]: pam_unix(cron:session): session closed for user root  
2026-08-16T19:09:01.885691-04:00 olivil CRON[13418]: pam_unix(cron:session): session closed for user kali  
2026-08-16T19:09:28.227734-04:00 olivil su[13287]: pam_unix(su-l:session): session closed for user testuser  
2026-08-16T19:10:00.643232-04:00 olivil sudo: kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/tail -n 30 /var/log/auth.log  
2026-08-16T19:10:00.644598-04:00 olivil sudo: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)  
(kali@olivil)~  
$
```

This showed both the failed and successful testuser authentication/session activity

3. Add the INTEL305 test rule

Added the temporary audit rule:

```
sudo auditctl -w /tmp/intel305-test -p wa -k intel305-test
```

The system displayed:

old style watch rules are slower

This was a warning, not an error.

4. Generate an audit event

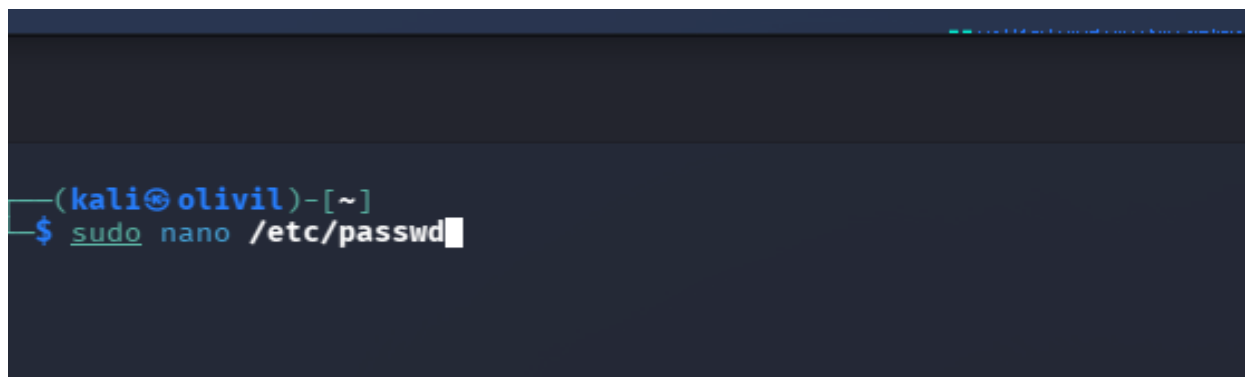
```
sudo touch /tmp/intel305-test
```

5. Search for the INTEL305 audit event

```
sudo ausearch -k intel305-test
```

6. Remove the temporary INTEL305 rule

```
sudo auditctl -d -w /tmp/intel305-test -p wa -k intel305-test
```



```
14-
s2-
h V
kali
Session Actions Edit View Help
GNU nano 9.1 /etc/passwd *
pipewire:x:987:987:system user for pipewire:/nonexistent:/usr/sbin/nologin
lightdm:x:109:110:Light Display Manager:/var/lib/lightdm:/bin/false
statd:x:110:65534::/var/lib/nfs:/usr/sbin/nologin
saned:x:111:111::/var/lib/saned:/usr/sbin/nologin
polkitd:x:986:986:User for polkitd:/usr/sbin/nologin
rtkit:x:112:112:RealtimeKit:/proc:/usr/sbin/nologin
colord:x:985:985:colord colour management daemon:/var/lib/colord:/usr/sbin/nologin
pcscd:x:984:984:PC/SC Smart Card Daemon:/usr/sbin/nologin
mysql:x:113:114:MariaDB Server:/nonexistent:/bin/false
geoclue:x:114:115::/var/lib/geoclue:/usr/sbin/nologin
Debian-snmpp:x:115:116::/var/lib/snmpp:/bin/false
ssldh:x:116:117::/nonexistent:/usr/sbin/nologin
cups-pk-helper:x:117:120:user for cups-pk-helper service:/nonexistent:/usr/sbin/nologin
redsocks:x:118:121::/var/run/redsocks:/usr/sbin/nologin
_gophish:x:119:123::/var/lib/gophish:/usr/sbin/nologin
iodine:x:120:65534::/run/iodine:/usr/sbin/nologin
miredo:x:121:65534::/var/run/miredo:/usr/sbin/nologin
redis:x:122:124::/var/lib/redis:/usr/sbin/nologin
postgres:x:123:125:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
mosquitto:x:124:126::/var/lib/mosquitto:/usr/sbin/nologin
inetsim:x:125:127::/var/lib/inetsim:/usr/sbin/nologin
_gvm:x:126:128::/var/lib/openvas:/usr/sbin/nologin
kali:x:1000:1000::/home/kali:/usr/bin/zsh
snort:x:127:131:Snort IDS:/var/log/snort:/usr/sbin/nologin
_dhcpd:x:980:980:DHCP Client Daemon:/var/lib/dhcpd:/sbin/nologin
iperf3:x:128:133::/nonexistent:/usr/sbin/nologin
testuser:x:1001:1001::1,3,4,0:/home/testuser:/bin/bash
Debian-exim:x:129:134::/var/spool/exim4:/usr/sbin/nologin
sbuidl:x:130:135:Debian source builder:/var/lib/sbuidl:/bin/bash
debian-tor:x:131:136::/var/lib/tor:/bin/false
stunnel:x:979:979:stunnel service system account:/var/run/stunnel:/usr/sbin/nologin
freerad:x:132:137::/etc/freeradius:/usr/sbin/nologin
student1:x:1002:1002::,/home/student1:/bin/bash
alice:x:1004:1004::,/home/alice:/bin/bash
bob:x:1005:1005::,/home/bob:/bin/bash
charlie:x:1006:1006::,/home/charlie:/bin/bash
olivil:x:1008:1008::,/home/olivil:/bin/bash
john:x:1009:1009::/home/john:/bin/sh
mary:x:1010:1010::/home/mary:/bin/sh
paul:x:1011:1011::/home/paul:/bin/sh
Ahmed:x:1012:1012::/home/Ahmed:/bin/sh

# INTEL30D audit test

^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify    ^_ Go To Line  M-E Redo
```

```
kali-linux-2025.4-vmware-a... X
kali@olivil: ~
Session Actions Edit View Help

(kali@olivil)-[~]
$ sudo auditctl -l
-w /var/log/auth.log -p wa -k user-logins
-w /etc/passwd -p wa -k passwd-modifications

(kali@olivil)-[~]
$ sudo auditctl -w /tmp/intel305-test -p wa -k intel305-test
old style watch rules are slower

(kali@olivil)-[~]
$ sudo touch /tmp/intel305-test

(kali@olivil)-[~]
$ sudo ausearch -k intel305-test

time→Sat Aug 15 15:12:27 2026
type=PROCTITLE msg=audit(1786821147.822:874): proctitle=617564697463746C002D77002F746D702F696E74656C3330352
D74657374002D70007761002D6B00696E74656C3330352D74657374
type=PATH msg=audit(1786821147.822:874): item=0 name="/tmp/" inode=1 dev=00:28 mode=041777 ouid=0 ogid=0 rd
ev=00:00 nametype=PARENT cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1786821147.822:874): cwd="/home/kali"
type=SOCKADDR msg=audit(1786821147.822:874): saddr=10000000000000000000000000000000
type=SYSCALL msg=audit(1786821147.822:874): arch=c000003e syscall=44 success=yes exit=1088 a0=4 a1=7ffe1e9f
a4b0 a2=440 a3=0 items=1 ppid=35408 pid=35409 auid=1000 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsg
id=0 tty=pts2 ses=3 comm="auditctl" exe="/usr/sbin/auditctl" subj=unconfined key=(null)
type=CONFIG_CHANGE msg=audit(1786821147.822:874): auid=1000 ses=3 subj=unconfined op=add_rule key="intel305
-test" list=4 res=1

time→Sat Aug 15 15:15:06 2026
type=PROCTITLE msg=audit(1786821306.888:909): proctitle=746F756368002F746D702F696E74656C3330352D74657374
type=PATH msg=audit(1786821306.888:909): item=1 name="/tmp/intel305-test" inode=383 dev=00:28 mode=0100644
ouid=0 ogid=0 rdev=00:00 nametype=CREATE cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1786821306.888:909): item=0 name="/tmp/" inode=1 dev=00:28 mode=041777 ouid=0 ogid=0 rd
ev=00:00 nametype=PARENT cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1786821306.888:909): cwd="/home/kali"
type=SYSCALL msg=audit(1786821306.888:909): arch=c000003e syscall=257 success=yes exit=3 a0=ffffffffffffff9
c a1=7ffc003b265b a2=941 a3=1b6 items=2 ppid=36734 pid=36735 auid=1000 uid=0 gid=0 euid=0 suid=0 fsuid=0 eg
id=0 sgid=0 fsgid=0 tty=pts2 ses=3 comm="touch" exe="/usr/bin/touch" subj=unconfined key="intel305-test"

(kali@olivil)-[~]
$
```

A temporary INTEL305 audit rule was created to demonstrate file monitoring. A test file was accessed, and ausearch successfully retrieved the resulting audit event. This confirmed that the auditd service was functioning correctly and recording monitored file activity. The temporary test rule was then removed.

Part 4 Reboot and Verification

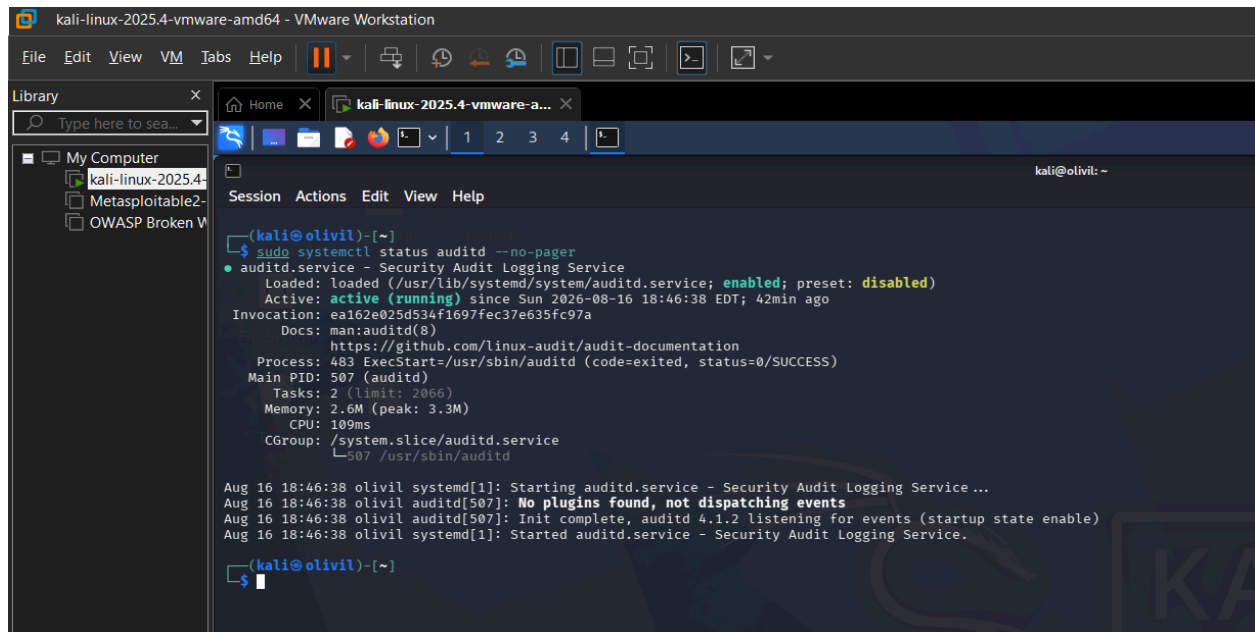
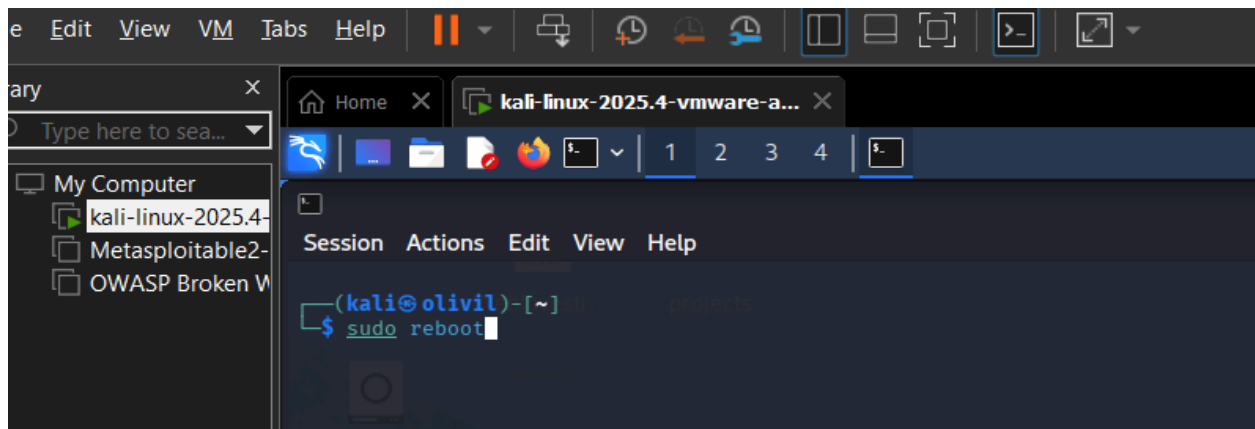
Commands Used:

Reboot

`sudo reboot`

After logging back into Kali

`sudo systemctl status auditd --no-pager`



The system was rebooted to verify persistence of the audit configuration. After restarting Kali, the `auditd` service was checked to confirm that it remained operational.

Part 2: Account Security Auditing

Exercise 2.1: Identify Inactive User Accounts

Step 1 Identify user login activity

Command used:

```
sudo lastlog | grep -v "Never"
```

Issue encountered:

Kali returned:

Now Used:

```
last -a
```

I checked the available login history to identify active and inactive user accounts. The original `lastlog` command was unavailable on this Kali system, so I used `last -a` instead without making system changes.

Step 2 Check account activity and password aging

Command used:

```
sudo chage -l testuser
```

Result: testuser had its password changed on August 17, 2026, with a 90-day maximum password age and 14-day warning period.

Step 3 Check for accounts with empty passwords

Command used:

```
sudo awk -F: '($2 == "") {print $1}' /etc/shadow
```

Result: No output.

Step 4 Identify accounts with UID 0

Command used:

```
awk -F: '($3 == "0") {print $1}' /etc/passwd
```

Result:

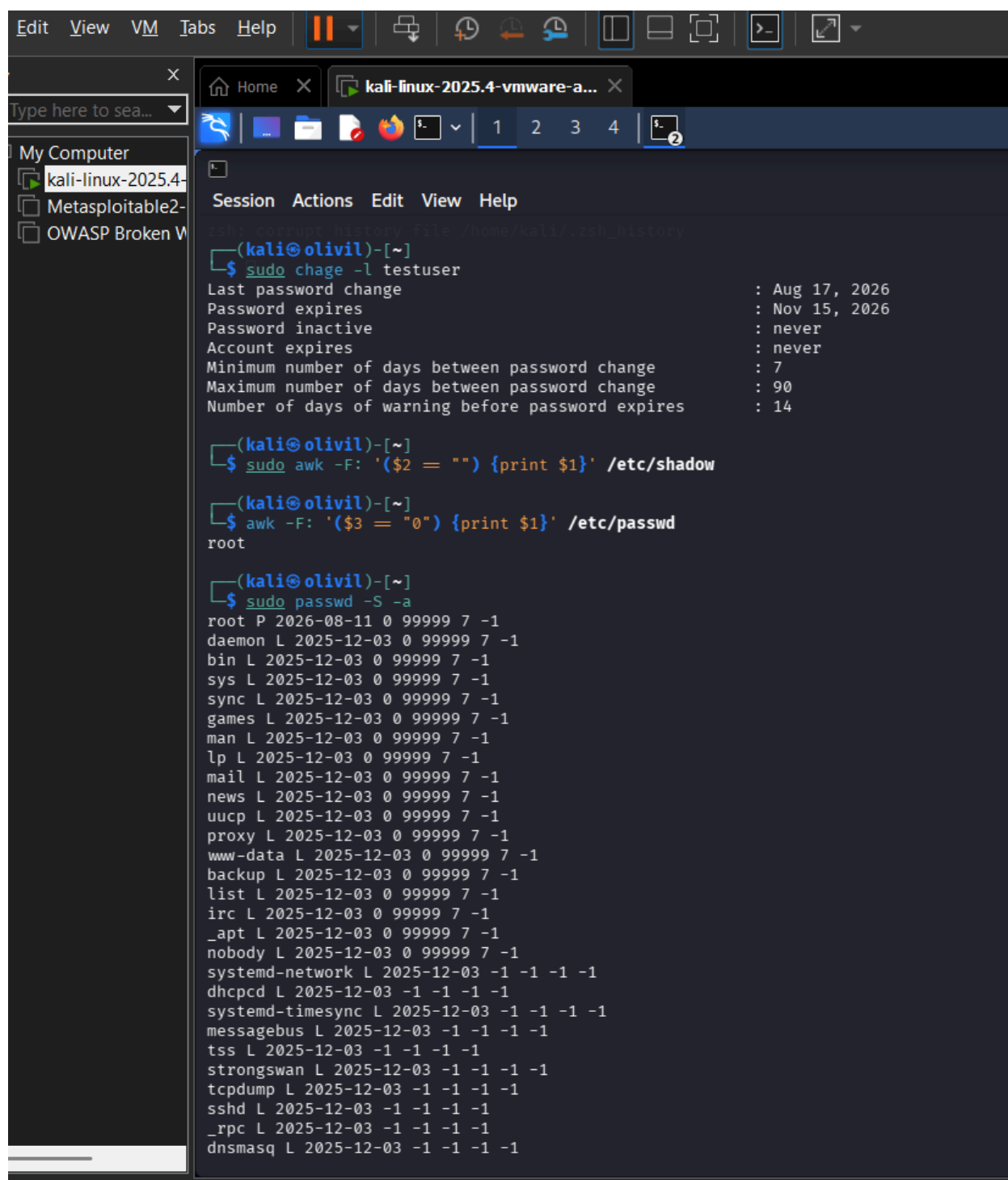
```
root
```

Step 5 Check password status of all users

Command used:

```
sudo passwd -S -a
```

Result: The command showed the password status of system and user accounts. Most system/service accounts were locked (L), while active accounts such as kali, testuser, student1, alice, bob, charlie, olivil, john, mary, and paul showed P



After reviewing the password status of all accounts and confirmed that most system accounts are locked while active user accounts have passwords configured. This helped identify which accounts are available for normal authentication.

Question 2.1: Why are inactive accounts a security risk?

Inactive accounts can become security vulnerabilities because attackers may exploit unused accounts to gain unauthorized access without being noticed. They also increase the number of accounts that need to be monitored and secured.

Question 2.2: What actions should be taken for accounts that haven't been used in 90+ days?

Review the account to confirm whether it is still needed. If it is no longer required, disable or remove it; if it is still needed, verify the owner and consider resetting the password and reviewing its permissions.

Exercise 2.2: Audit User Permissions and Group Memberships

Commands used

1. Check all groups for a specific user

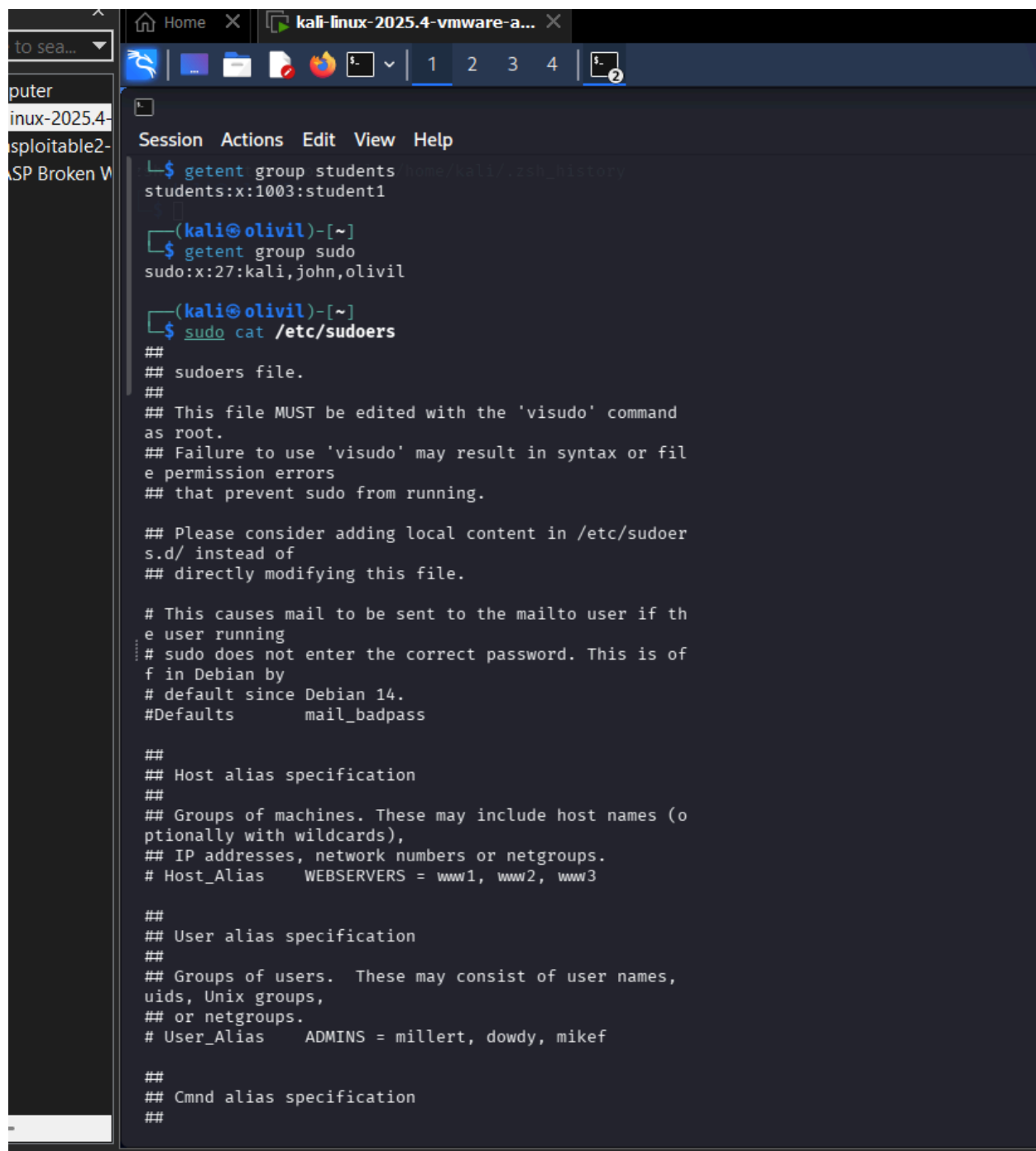
```
getent group students
```

2. Check the sudo group

```
getent group sudo
```

3. Review the sudoers file configuration

```
sudo cat /etc/sudoers
```



The screenshot shows a terminal window with the following commands and output:

```
Session Actions Edit View Help
└─$ getent group students home/kali/.ssh_history
students:x:1003:student1

(kali@olivil)-[~]
└─$ getent group sudo
sudo:x:27:kali,john,olivil

(kali@olivil)-[~]
└─$ sudo cat /etc/sudoers
##
## sudoers file.
##
## This file MUST be edited with the 'visudo' command
as root.
## Failure to use 'visudo' may result in syntax or fil
e permission errors
## that prevent sudo from running.

## Please consider adding local content in /etc/sudoer
s.d/ instead of
## directly modifying this file.

# This causes mail to be sent to the mailto user if th
e user running
# sudo does not enter the correct password. This is of
f in Debian by
# default since Debian 14.
#Defaults      mail_badpass

##
## Host alias specification
##
## Groups of machines. These may include host names (o
ptionally with wildcards),
## IP addresses, network numbers or netgroups.
# Host_Alias    WEBSERVERS = www1, www2, www3

##
## User alias specification
##
## Groups of users. These may consist of user names,
uids, Unix groups,
## or netgroups.
# User_Alias    ADMINS = millert, dowdy, mikef

##
## Cmnd alias specification
##
```

4. List users with valid login shells

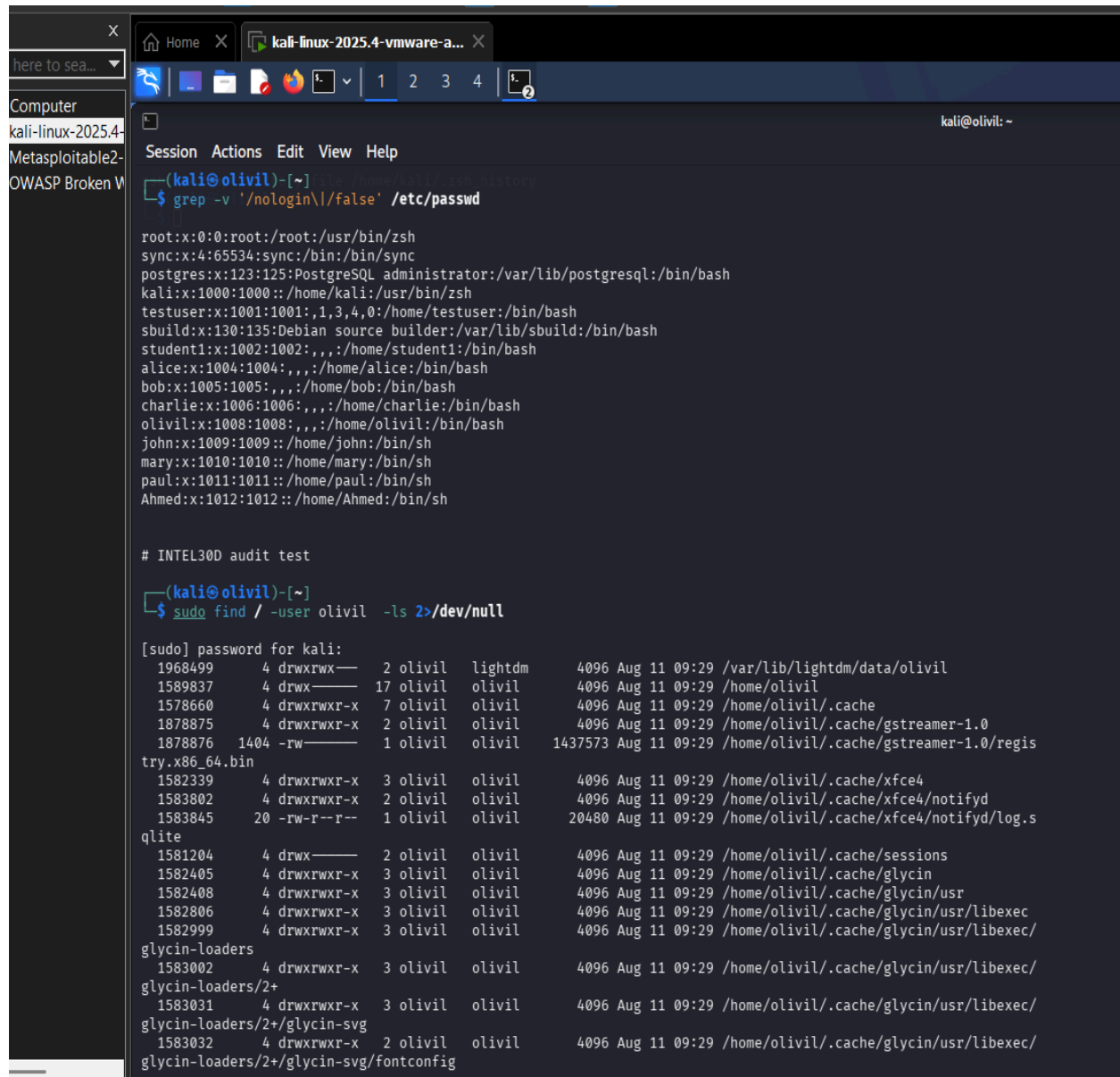
`grep -v '/nologin|/false' /etc/passwd`

5. Find files owned by specific users:

`sudo find / -user olivil -ls 2>/dev/null`

6. Find SUID files (potential security risk)

`sudo find / -perm -4000 -type f -ls 2>/dev/null`



```
(kali@olivil)-[~]
$ grep -v '/nologin|/false' /etc/passwd

root:x:0:0:root:/root:/usr/bin/zsh
sync:x:4:65534:sync:/bin:/bin/sync
postgres:x:123:125:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
kali:x:1000:1000::/home/kali:/usr/bin/zsh
testuser:x:1001:1001:,,,:/home/testuser:/bin/bash
sbuidl:x:130:135:Debian source builder:/var/lib/sbuidl:/bin/bash
student1:x:1002:1002:,,,:/home/student1:/bin/bash
alice:x:1004:1004:,,,:/home/alice:/bin/bash
bob:x:1005:1005:,,,:/home/bob:/bin/bash
charlie:x:1006:1006:,,,:/home/charlie:/bin/bash
olivil:x:1008:1008:,,,:/home/olivil:/bin/bash
john:x:1009:1009:/home/john:/bin/sh
mary:x:1010:1010:/home/mary:/bin/sh
paul:x:1011:1011:/home/paul:/bin/sh
Ahmed:x:1012:1012:/home/Ahmed:/bin/sh

# INTEL30D audit test

(kali@olivil)-[~]
$ sudo find / -user olivil -ls 2>/dev/null

[sudo] password for kali:
1968499      4 drwxrwx---  2 olivil  lightdm      4096 Aug 11 09:29 /var/lib/lightdm/data/olivil
1589837      4 drwx----- 17 olivil  olivil       4096 Aug 11 09:29 /home/olivil
1578660      4 drwxrwxr-x  7 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache
1878875      4 drwxrwxr-x  2 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/gstreamer-1.0
1878876    1404 -rw-----  1 olivil  olivil    1437573 Aug 11 09:29 /home/olivil/.cache/gstreamer-1.0/registries
1582339      4 drwxrwxr-x  3 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/xfce4
1583802      4 drwxrwxr-x  2 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/xfce4/notifyd
1583845     20 -rw-r--r--  1 olivil  olivil    20480 Aug 11 09:29 /home/olivil/.cache/xfce4/notifyd/log.s
qlite
1581204      4 drwx-----  2 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/sessions
1582405      4 drwxrwxr-x  3 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/glycin
1582408      4 drwxrwxr-x  3 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/glycin/usr
1582806      4 drwxrwxr-x  3 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/glycin/usr/libexec
1582999      4 drwxrwxr-x  3 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/glycin/usr/libexec/
glycin-loaders
1583002      4 drwxrwxr-x  3 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/glycin/usr/libexec/
glycin-loaders/2+
1583031      4 drwxrwxr-x  3 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/glycin/usr/libexec/
glycin-loaders/2+/glycin-svg
1583032      4 drwxrwxr-x  2 olivil  olivil       4096 Aug 11 09:29 /home/olivil/.cache/glycin/usr/libexec/
glycin-loaders/2+/glycin-svg/fontconfig
```

Reviewed user groups, sudo privileges, valid login accounts, files owned by **olivil**, and SUID files on the system. The checks helped identify privileged users and files that could require additional security monitoring. The audit checks were completed successfully.

Question 2.3: Why are SUID files a potential security concern?

SUID files run with the permissions of the file's owner, often **root**, even when executed by a normal user. If a vulnerable SUID program is exploited, an attacker could potentially gain elevated/root privileges.

Question 2.4: What is the principle of least privilege, and how does it apply to user management?

The principle of least privilege means users should receive only the permissions they need to perform their tasks. In user management, this means limiting administrative privileges, controlling group membership, and avoiding unnecessary access to sensitive files and systems.

Part 3: User Activity Monitoring

Exercise 3.1: Analyze Authentication Logs

Commands used

1. View successful login history

```
sudo last -a
```

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@olivil)-[~]
$ sudo last -a

[sudo] password for kali:
kali      tty7          Mon Aug 17 02:07 - still logged in      :0
lightdm   tty7          Mon Aug 17 02:06 - 02:07 (00:00)      :0
testuser  pts/0         Sun Aug 16 19:08 - 19:09 (00:00)      :0
kali      tty7          Sun Aug 16 18:47 - still logged in      :0
lightdm   tty7          Sun Aug 16 18:47 - 18:47 (00:00)      :0
kali      tty7          Sat Aug 15 21:48 - still logged in      :0
lightdm   tty7          Sat Aug 15 21:48 - 21:48 (00:00)      :0
testuser  pts/1         Sat Aug 15 14:20 - 14:20 (00:00)      :0
kali      tty7          Sat Aug 15 14:01 - still logged in      :0
lightdm   tty7          Sat Aug 15 14:01 - 14:01 (00:00)      :0
testuser  pts/2         Sat Aug 15 09:29 - 09:30 (00:01)      :0
kali      tty7          Sat Aug 15 09:02 - still logged in      :0
lightdm   tty7          Sat Aug 15 09:02 - 09:02 (00:00)      :0
kali      pts/5         Sat Aug 15 08:44 - 08:46 (00:01)      ::1
lightdm   tty8          Sat Aug 15 08:11 - 08:12 (00:00)      :1
kali      pts/4         Sat Aug 15 07:58 - 08:59 (01:00)      ::1
kali      pts/3         Sat Aug 15 07:37 - 07:38 (00:01)      ::1
kali      tty7          Sat Aug 15 07:06 - still logged in      :0
lightdm   tty7          Sat Aug 15 06:56 - 07:06 (00:10)      :0
kali      tty7          Tue Aug 11 09:50 - still logged in      :0
lightdm   tty7          Tue Aug 11 09:50 - 09:50 (00:00)      :0
kali      pts/0         Tue Aug 11 09:46 - still logged in      :0
olivil    tty7          Tue Aug 11 09:29 - still logged in      :0
lightdm   tty7          Tue Aug 11 09:29 - 09:29 (00:00)      :0
lightdm   tty7          Tue Aug 11 08:56 - still logged in      :0
olivil    console       Tue Aug 11 08:52 - 08:55 (00:03)      :0
lightdm   tty7          Tue Aug 11 08:33 - still logged in      :0
lightdm   tty7          Tue Aug 11 07:31 - still logged in      :0
lightdm   tty7          Mon Aug 10 21:04 - still logged in      :0
lightdm   tty7          Mon Aug 10 20:56 - still logged in      :0
lightdm   tty7          Mon Aug 10 20:36 - still logged in      :0
lightdm   tty7          Mon Aug 10 19:54 - still logged in      :0
lightdm   tty7          Mon Aug 10 19:46 - still logged in      :0
```

2. Attempt to view failed login history

`sudo last -b`

This did **not work on your Kali system** because your `last` utility uses `wtmpdb`, which does not support the `-b` option.

3. Search SSH logs for failed attempts

```
sudo journalctl _SYSTEMD_UNIT=ssh.service | grep -i "failed"
```

4. Search the system journal for authentication failures

```
sudo journalctl | grep -Ei "failed password|authentication failure|invalid user"
```

5. Monitor the authentication log in real time

```
sudo tail -f /var/log/auth.log
```

6. Count failed-password attempts by user

```
sudo grep "Failed password" /var/log/auth.log | awk '{print $(NF-5)}' | sort | uniq -c  
| sort -nr
```

7. Check specifically for failed root login attempts

```
sudo grep "root" /var/log/auth.log | grep "Failed"
```

8. Monitor currently logged-in users

```
w
```

9. Display detailed information about logged-in users

```
who -a
```

10. View the last 20 login records

```
last -n 20
```

kali@olivil: ~

(kali@olivil)-[~]

\$ sudo last -b

[sudo] password for kali:

last: invalid option -- 'b'

Usage: wtmpdb [command] [options]

Commands: last, boot, boottime, rotate, shutdown, import

Options for last:

-a, --hostlast	Display hostnames as last entry
-d, --dns	Translate IP addresses into a hostname
-f, --file FILE	Use FILE as wtmpdb database
-F, --fulltimes	Display full times and dates
-i, --ip	Translate hostnames to IP addresses
-j, --json	Generate JSON output
-n, --limit N, -N	Display only first N entries
-p, --present TIME	Display who was present at TIME
-R, --nohostname	Don't display hostname
-S, --service	Display PAM service used to login
-s, --since TIME	Display who was logged in after TIME
-t, --until TIME	Display who was logged in until TIME
-w, --fullnames	Display full IP addresses and user and domain names
-x, --system	Display system shutdown entries
--time-format FORMAT	Display timestamps in the specified FORMAT: notime short full iso
[username ...]	Display only entries matching these arguments
[tty ...]	Display only entries matching these arguments

TIME must be in the format "YYYY-MM-DD HH:MM:SS"

Options for boot (writes boot entry to wtmpdb):

-f, --file FILE Use FILE as wtmpdb database

kali@olivil: ~

(kali@olivil)-[~]

\$ sudo journalctl _SYSTEMD_UNIT=ssh.service | grep -i "failed"~

Journal file /var/log/journal/b69758c0cad3481e967dcad827001d56/system@000658b9f79bae7f-6fae008802c6d6f3.journal~ is truncated, ignoring file.

(kali@olivil)-[~]

\$ sudo journalctl | grep -Ei "failed password|authentication failure|invalid user"

Journal file /var/log/journal/b69758c0cad3481e967dcad827001d56/system@000658b9f79bae7f-6fae008802c6d6f3.journal~ is truncated, ignoring file.

Jul 09 16:18:28 kali lightdm[1496]: pam_unix(lightdm:auth): authentication failure; logname= uid=0 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=kali

Jul 10 05:40:29 kali xfce4-screensaver-dialog[220887]: pam_unix(xfce4-screensaver:auth): authentication failure; logname=kali uid=1000 euid=1000 tty=:0.0 ruser= rhost= user=kali

Jul 10 05:45:36 kali xfce4-screensaver-dialog[223354]: pam_unix(xfce4-screensaver:auth): authentication failure; logname=kali uid=1000 euid=1000 tty=:0.0 ruser= rhost= user=kali

Jul 10 06:33:15 kali sudo[2539]: pam_unix(sudo:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=kali

Jul 14 01:05:25 kali sudo[68881]: pam_unix(sudo:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=kali

Jul 14 05:10:01 kali xfce4-screensaver-dialog[70290]: pam_unix(xfce4-screensaver:auth): authentication failure; logname=kali uid=1000 euid=1000 tty=:0.0 ruser= rhost= user=kali

Jul 17 23:50:29 kali xfce4-screensaver-dialog[25802]: pam_unix(xfce4-screensaver:auth): authentication failure; logname=kali uid=1000 euid=1000 tty=:0.0 ruser= rhost= user=kali

Aug 07 13:03:09 kali lightdm[1443]: pam_unix(lightdm:auth): authentication failure; logname= uid=0 euid=0 tty=:0 ruser= rhost= user=olivil

Aug 07 13:35:14 olivil su[11504]: pam_unix(su-l:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/2 ruser=kali rhost= user=john

Aug 09 10:28:37 olivil sudo[3043]: pam_unix(sudo:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=kali

Aug 09 11:10:17 olivil su[24296]: pam_unix(su-l:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/2 ruser=kali rhost= user=olivil

Aug 09 11:17:09 olivil su[27769]: pam_unix(su-l:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=olivil

Aug 09 11:17:34 olivil su[28057]: pam_unix(su-l:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=olivil

Aug 10 17:54:40 olivil su[29979]: pam_unix(su-l:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=mary

Aug 10 17:59:28 olivil su[31366]: pam_unix(su-l:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/0 ruser=kali rhost= user=mary

Aug 10 18:58:24 olivil lightdm[1455]: pam_unix(lightdm:auth): authentication failure; logname= uid=0 euid=0 tty=:0 ruser= rhost= user=kali

Aug 10 19:01:16 olivil lightdm[1457]: pam_unix(lightdm:auth): authentication failure; logname= uid=0 euid=0 tty=:0 ruser= rhost= user=kali

Aug 10 19:04:54 olivil lightdm[1453]: pam_unix(lightdm:auth): authentication failure; logname= uid=0 euid=0 tty=:0 ruser= rhost= user=kali

Aug 10 19:05:03 olivil lightdm[1458]: pam_unix(lightdm:auth): authentication failure; logname= uid=0 euid=0 tty=:0 ruser= rhost= user=kali

Question 3.1: What patterns might indicate a brute-force attack attempt?

- Many failed login attempts within a short period.
- Repeated attempts against the same username.
- Attempts against multiple usernames from the same IP address.
- Login attempts occurring continuously or at regular short intervals.
- Attempts coming from an unknown or suspicious IP address.
- Repeated attempts against privileged accounts such as `root`.
- Numerous authentication failures followed by a successful login, which could indicate that the attacker eventually guessed the password.

Question 3.2: Why is it important to monitor root login attempts?

Monitoring root login attempts is important because an attacker who successfully gains access to root can potentially:

- Modify or delete system files.
- Create or modify user accounts.
- Install malicious software.
- Disable security controls.
- Access sensitive information.
- Establish persistence.
- Take complete control of the system.

Exercise 3.2: Implement Account Lockout Policies

The prescribed `pam_tally2` method was not implemented because `pam_tally2` is unavailable on the current Kali Linux installation. The system provides `pam_faillock` instead. To avoid modifying the system-wide PAM authentication configuration and potentially disrupting existing authentication, this exercise was skipped.

Question 3.3: What are the trade-offs between security and usability when implementing account lockout policies?

Account lockout improves security by stopping repeated password-guessing attempts. However, it can inconvenience legitimate users who enter the wrong password and may allow attackers to deliberately lock accounts. A reasonable limit and lockout time helps balance security and usability.

Part 4: Sudo Access Management

Exercise 4.1: Configure Fine-Grained Sudo Permissions

Commands used:

1. Check the test user

```
id locktest
```

2. Check existing sudo permissions

```
sudo -l -U locktest
```

3. Back up the sudoers file

```
sudo cp /etc/sudoers /etc/sudoers.backup
```

4. Verify the backup

```
025.4-
ble2-
ken V

Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@olivil)-[~]
$ cd ~
(kali@olivil)-[~]
$ cd ~
nano security_audit.sh
```

Pasted into nano file:

```
#!/bin/bash
# User Access Security Audit Script

echo "=== User Access Security Audit ==="
echo ""

echo "1. Checking for users with UID 0:"
awk -F: '($3 == "0") {print $1}' /etc/passwd
echo ""

echo "2. Checking for accounts with empty passwords:"
sudo awk -F: '($2 == "") {print $1}' /etc/shadow
echo ""

echo "3. Checking for users with sudo access:"
getent group sudo
echo ""

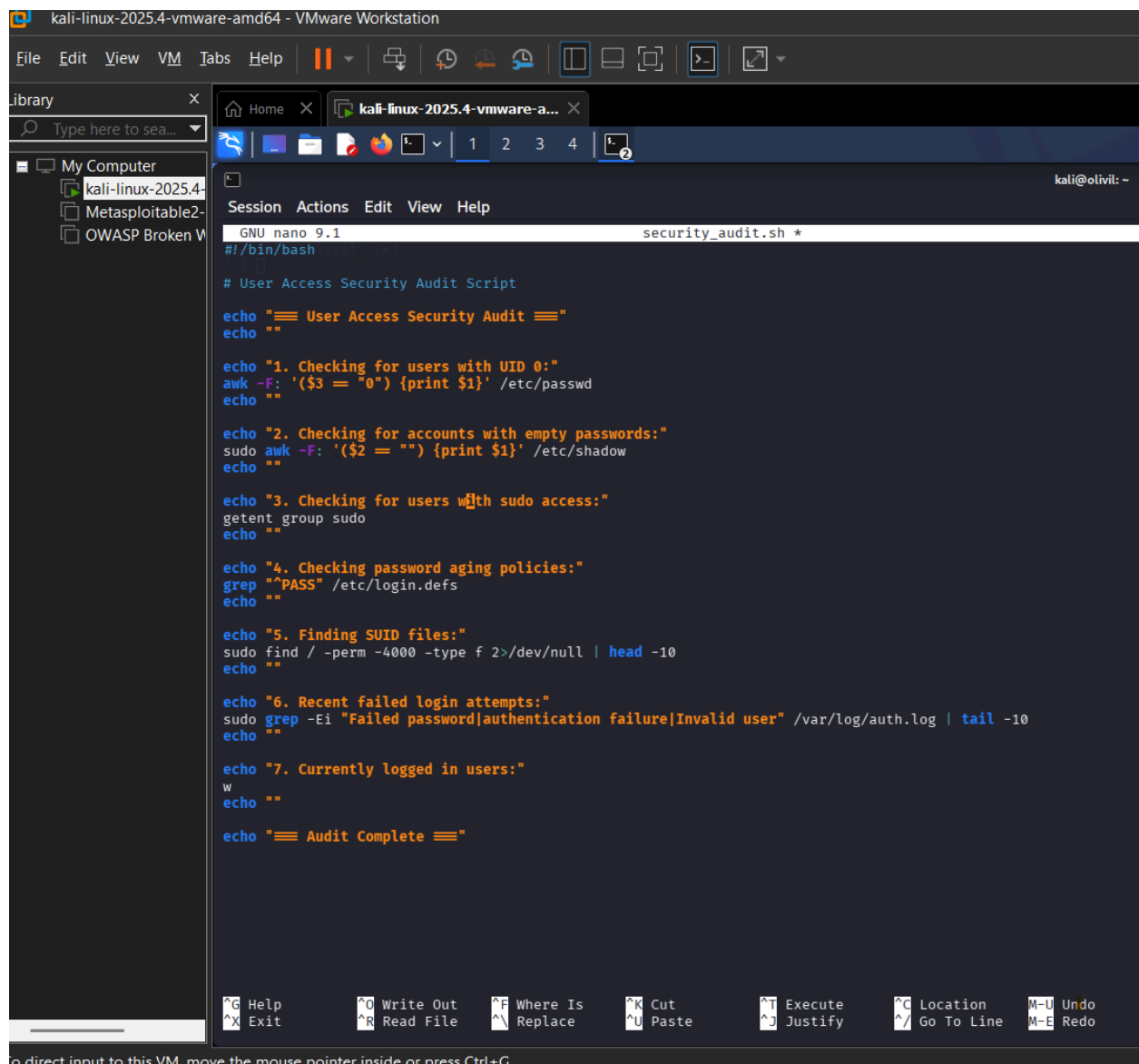
echo "4. Checking password aging policies:"
grep "^PASS" /etc/login.defs
echo ""

echo "5. Finding SUID files:"
sudo find / -perm -4000 -type f 2>/dev/null | head -10
echo ""
```

```
echo "6. Recent failed login attempts:"
sudo lastb | head -10
echo ""
```

```
echo "7. Currently logged in users:"
w
echo ""
```

```
echo "=== Audit Complete ==="
```



The screenshot shows a Kali Linux virtual machine running in VMware Workstation. The terminal window displays the execution of a script named `security_audit.sh`. The script performs several security checks, including checking for users with UID 0, accounts with empty passwords, users with sudo access, password aging policies, SUID files, recent failed login attempts, and currently logged-in users. The script concludes with a message indicating the audit is complete.

```
kali@olivil: ~
Session Actions Edit View Help
GNU nano 9.1 security_audit.sh *
#!/bin/bash

# User Access Security Audit Script

echo "=== User Access Security Audit ==="
echo ""

echo "1. Checking for users with UID 0:"
awk -F: '($3 == "0") {print $1}' /etc/passwd
echo ""

echo "2. Checking for accounts with empty passwords:"
sudo awk -F: '($2 == "") {print $1}' /etc/shadow
echo ""

echo "3. Checking for users with sudo access:"
getent group sudo
echo ""

echo "4. Checking password aging policies:"
grep "^PASS" /etc/login.defs
echo ""

echo "5. Finding SUID files:"
sudo find / -perm -4000 -type f 2>/dev/null | head -10
echo ""

echo "6. Recent failed login attempts:"
sudo grep -Ei "Failed password|authentication failure|Invalid user" /var/log/auth.log | tail -10
echo ""

echo "7. Currently logged in users:"
w
echo ""

echo "=== Audit Complete ==="
```

Saved the script = Ctrl O, Exit = X

Made it executable

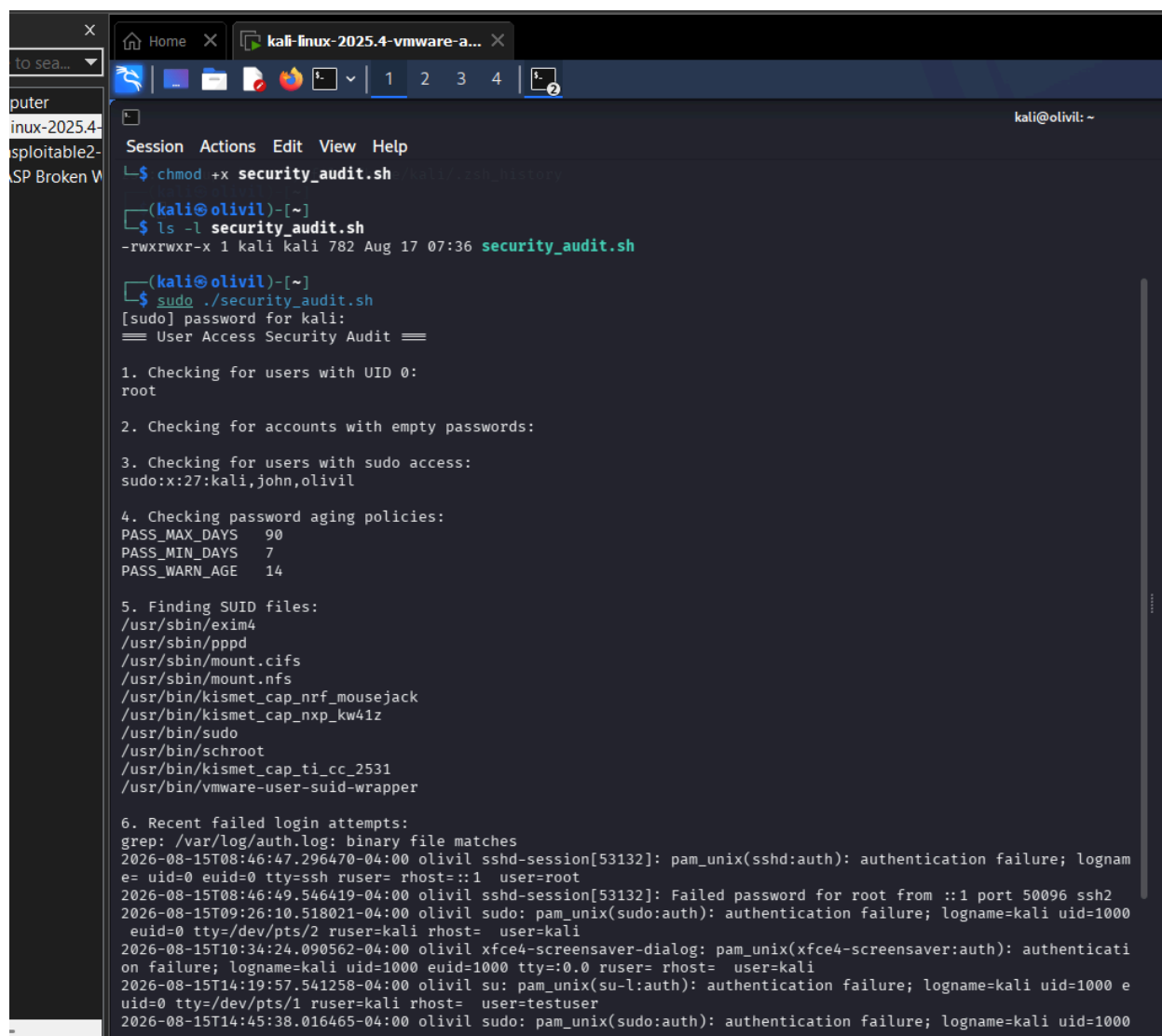
```
chmod +x security_audit.sh
```

Verified:

```
ls -l security_audit.sh
```

Ran the Audit File:

```
sudo ./security_audit.sh
```

A screenshot of a terminal window titled 'kali@olivil: ~'. The terminal shows the execution of a security audit script. The user first runs 'chmod +x security_audit.sh' and then 'sudo ./security_audit.sh'. The script outputs a series of checks: 1. Checking for users with UID 0: root. 2. Checking for accounts with empty passwords. 3. Checking for users with sudo access: sudo:x:27:kali,john,olivil. 4. Checking password aging policies: PASS_MAX_DAYS 90, PASS_MIN_DAYS 7, PASS_WARN_AGE 14. 5. Finding SUID files: /usr/sbin/exim4, /usr/sbin/pppd, /usr/sbin/mount.cifs, /usr/sbin/mount.nfs, /usr/bin/kismet_cap_nrf_mousejack, /usr/bin/kismet_cap_nxp_kw41z, /usr/bin/sudo, /usr/bin/schroot, /usr/bin/kismet_cap_ti_cc_2531, /usr/bin/vmware-user-suid-wrapper. 6. Recent failed login attempts: grep: /var/log/auth.log: binary file matches. The output shows several failed login attempts for root, kali, and testuser.

created the automated security check bash script and it ran successfully

Question 5.1: What additional checks would you add to this security audit script?

I would add checks for inactive accounts, expired passwords, failed login attempts by IP address, unusual user accounts, SSH configuration, unauthorized cron jobs, and recently modified system files.

Exercise 5.2: Implement User Access Review Process

1. Create a user access report:

Commands Used:

```
#!/bin/bash
```

```
# Generate user access report
```

```
echo "User Access Report - $(date)" > user_access_report.txt
```

```
echo "===== " >>
```

```
user_access_report.txt
```

```
echo "" >> user_access_report.txt
```

```
echo "All User Accounts:" >> user_access_report.txt
```

```
awk -F: '{print $1 " (UID: " $3 ")"}' /etc/passwd >> user_access_report.txt
```

```
echo "" >> user_access_report.txt
```

```
echo "Users with Shell Access:" >> user_access_report.txt
```

```
grep -v '/nologin\|/false' /etc/passwd | awk -F: '{print $1}' >>
```

```
user_access_report.txt
```

```
echo "" >> user_access_report.txt
```

```
echo "Last Login Information:" >> user_access_report.txt
```

```
sudo lastlog >> user_access_report.txt
```

```
cat user_access_report.txt
```

The screenshot shows a Kali Linux terminal window with a dark theme. The window title is "kali-linux-2025.4-vmware-a...". The terminal displays the following commands and output:

```
GNU nano 9.1 user_access_report.sh *
#!/bin/bash

# Generate user access report

echo "User Access Report - $(date)" > user_access_report.txt
echo "=====" > user_access_report.txt
echo "" > user_access_report.txt

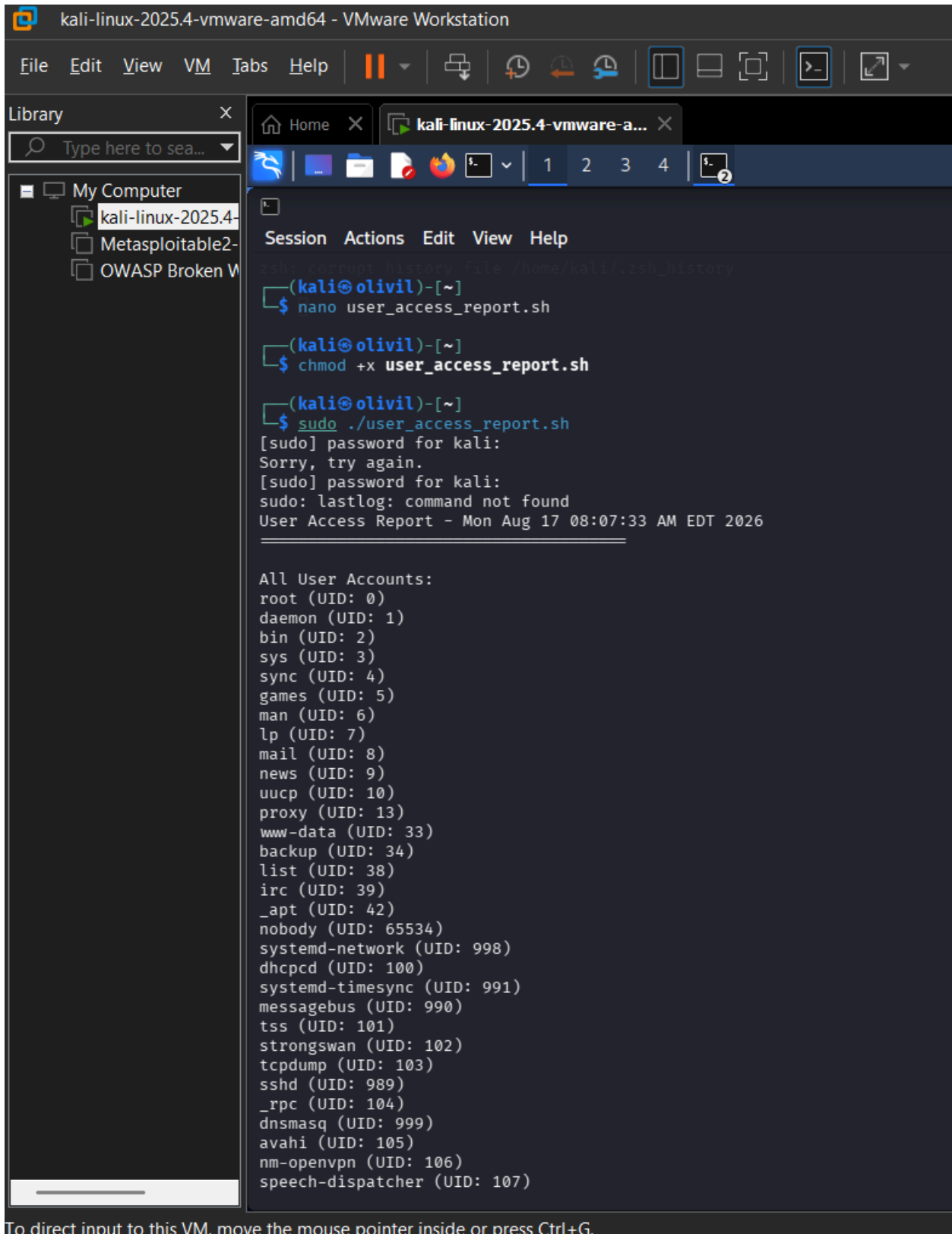
echo "All User Accounts:" >> user_access_report.txt
awk -F: '{print $1 " (UID: " $3 ")"}' /etc/passwd >> user_access_report.txt
echo "" >> user_access_report.txt

echo "Users with Shell Access:" >> user_access_report.txt
grep -v '/nologin\\|/false' /etc/passwd | awk -F: '{print $1}' >> user_access_report.txt
echo "" >> user_access_report.txt

echo "Last Login Information:" >> user_access_report.txt
sudo lastlog >> user_access_report.txt

cat user_access_report.txt
```

The terminal window includes a menu bar with "Session", "Actions", "Edit", "View", and "Help". The left sidebar shows a file explorer with "My Computer" and a list of files: "kali-linux-2025.4", "Metasploitable2-", and "OWASP Broken V". The top toolbar contains various icons for file operations and window management.



2. Document findings and recommendations:
Create a file security_recommendations.txt with your findings.

```
kali@olivil: ~  
GNU nano 9.1 security_recommendations.txt *  
Security Recommendations  
1. Review user accounts regularly and remove unnecessary accounts.  
2. Disable inactive or unused accounts.  
3. Enforce strong password and password-aging policies.  
4. Review sudo privileges and apply least-privilege access.  
5. Monitor failed login attempts for suspicious activity.  
6. Review SUID files and remove unnecessary SUID permissions.  
7. Monitor privileged accounts and root access.
```

```
kali@olivil: ~  
(kali@olivil)-[~]  
$ nano security_recommendations.txt  
(kali@olivil)-[~]  
$ cat security_recommendations.txt  
Security Recommendations  
1. Review user accounts regularly and remove unnecessary accounts.  
2. Disable inactive or unused accounts.  
3. Enforce strong password and password-aging policies.  
4. Review sudo privileges and apply least-privilege access.  
5. Monitor failed login attempts for suspicious activity.  
6. Review SUID files and remove unnecessary SUID permissions.  
7. Monitor privileged accounts and root access.  
(kali@olivil)-[~]  
$
```

Question 5.2: How often should user access reviews be conducted in a production environment?

User access reviews should be conducted at least quarterly, with additional reviews whenever employees change roles, leave the organization, or receive new privileges.